

DPDP COMPLIANCE AUDIT

documenso

Digital Personal Data Protection Act 2023



66/100

Grade C — Needs Work

Scanned: 05 April 2026

Files indexed: 1787

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

This codebase has 7 critical compliance gap(s) that require immediate attention under the Digital Personal Data Protection Act 2023. An additional 3 significant gap(s) were identified that should be addressed within 30 days. The estimated total remediation effort is 4.1–15.6 engineering days.

Total findings: 23

HIGH: 7

MEDIUM: 3

PASS: 12

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	19/22 (86%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	10/10 (100%)	PASS
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	4.0/8 (50%)	WARN
Section 8(6)	8	5.6/8 (70%)	WARN
Section 9	6	6/6 (100%)	PASS
Section 11	6	6/6 (100%)	PASS
Section 16	4	0/4 (0%)	FAIL
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	0/4 (0%)	FAIL

Estimated Total Remediation Effort: 4.1–15.6 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Analytics SDK

PII fields: email, pii_field

envelope-signing-complete-dialog.tsx → use-analytics.ts

Flow 2: Analytics SDK

PII fields: address

router.ts → telemetry-client.ts

Flow 3: Application Logs

PII fields: email

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts

Flow 4: Application Logs

PII fields: email

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts → hono.ts → implementation.ts

Flow 5: Application Logs

PII fields: email, address

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts → hono.ts → implementation.ts → authenticated.ts

Rule	Section	Severity	File
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	HIGH	packages/lib/universal/get-ip-address.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	packages/lib/client-only/hooks/use-analytics.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	packages/lib/server-only/telemetry/telemetry-client.ts
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	HIGH	N/A
CONSENT_MISSING	Section 6 — Consent	HIGH	MULTIPLE
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	packages/lib/jobs/definitions/internal/sync-email-domains.handler.ts
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	packages/lib/server-only/user/service-accounts/legacy-service-account.ts
NO_ERROR_HANDLING_IN_AUTH	Section 8(6) — Breach	MEDIUM	apps/remix/app/routes/_authenticated+/admin+/documents_index.tsx
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	MEDIUM	apps/remix/app/routes/_internal+/_htmltopdf+/audit-log.tsx
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/routes/_internal+/_htmltopdf+/audit-log.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/components/tables/inbox-table.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/routes/_unauthenticated+/o.\$orgUrl.signin.tsx

CONSENT_PRESENT	Section 6 — Consent	PASS	packages/auth/server/index.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/trpc/server/trpc.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/auth/server/lib/utils/delete-account-provider.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/trpc/server/context.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/components/general/document/document-edit-form.tsx
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	apps/remix/app/components/dialogs/account-delete-dialog.tsx
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	N/A
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	packages/api/hono.ts

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (26–98 hours)

Fix immediately — these represent the highest legal exposure.

- Cross Border Transfer Risk — universal/get-ip-address.ts (4–12 hrs)
- Pii Flow To Analytics Without Consent — hooks/use-analytics.ts (4–16 hrs)
- Pii Flow To Analytics Without Consent — telemetry/telemetry-client.ts (4–16 hrs)
- Grievance Officer Missing (1–4 hrs)
- Consent Missing — MULTIPLE (11–44 hrs)
- Plaintext Pii In Logs — internal/sync-email-domains.handler.ts (1–3 hrs)
- Plaintext Pii In Logs — service-accounts/legacy-service-account.ts (1–3 hrs)

Week 2 — High Priority (5–19 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- No Error Handling In Auth — admin+/documents._index.tsx (1–3 hrs)
- Incomplete Deletion Coverage (2–8 hrs)
- Audit Trail Partial — [_htmltopdf]+/audit-log.tsx (2–8 hrs)

Week 4 — Advisory (2–8 hours)

Address before next compliance review.

■ Data Portability Missing (2–8 hrs)

Total estimated remediation effort: 33–125 hours (4.1–15.6 engineering days)

Details

Finding 1 of 23

[Section 16 — Cross-Border Transfer]

1. [HIGH] CROSS_BORDER_TRANSFER_RISK — packages / lib / universal / get-ip-address.ts:31

Evidence snippet: // Check for True-Client-IP (Akamai and Cloudflare)

Estimated fix time: 4–12 hours

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Finding 2 of 23

[Section 6 — Consent / Section 5 — Purpose Limitation]

2. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — packages / lib / client-only / hooks / use-analytics.ts

Estimated fix time: 4–16 hours

PII flows from envelope-signing/envelope-signing-complete-dialog.tsx to analytics service (hooks/use-analytics.ts) through 1 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Fix:

1. Add analytics consent checkbox at envelope-signing/envelope-signing-complete-dialog.tsx before user data is collected.
2. Store analytics consent separately from auth consent in your consent table with purpose='analytics'.
3. Check analytics consent in hooks/use-analytics.ts before calling the analytics SDK.
4. If analytics is essential, disclose it in your privacy notice under Section 5 and obtain consent under Section 6.

Finding 3 of 23

[Section 6 — Consent / Section 5 — Purpose Limitation]

3. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — packages / lib / server-only / telemetry / telemetry-client.ts

Estimated fix time: 4–16 hours

PII flows from server/router.ts to analytics service (telemetry/telemetry-client.ts) through 1 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Fix:

1. Add analytics consent checkbox at server/router.ts before user data is collected.
2. Store analytics consent separately from auth consent in your consent table with purpose='analytics'.
3. Check analytics consent in telemetry/telemetry-client.ts before calling the analytics SDK.
4. If analytics is essential, disclose it in your privacy notice under Section 5 and obtain consent under Section 6.

Finding 4 of 23

[Section 13 — Grievance Redressal]

4. [HIGH] GRIEVANCE_OFFICER_MISSING — N / A**Estimated fix time:** 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Fix:

1. Publish a named Grievance Officer (or DPO) with email and, if possible, postal address in your privacy policy or legal page.
2. Add a dedicated route (e.g. /grievance or /contact-dpo) or config keys such as GRIEVANCE_OFFICER_EMAIL referenced from that page.
3. Describe the redressal process: how to lodge a grievance, expected timeline (e.g. 30 days), and escalation path.

Finding 5 of 23

[Section 6 — Consent]

5. [HIGH] CONSENT_MISSING — MULTIPLE:3

Evidence snippet: import { validateFields as validateEmailFields } from '@documenso/lib/advanced-fields-validation/validate-fields';

Estimated fix time: 11–44 hours**Affected files (16):**

- packages/ui/primitives/document-flow/field-items-advanced-settings/email-field.tsx
- apps/remix/app/routes/_authenticated+/admin+/email-domains._index.tsx
- packages/trpc/server/template-router/schema.ts
- apps/remix/app/components/forms/signin.tsx
- packages/lib/universal/get-ip-address.ts
- apps/remix/app/routes/_internal+/_htmltopdf+/certificate.tsx
- ... and 10 more files

Personal data collection and API endpoint detected with no consent mechanism. Detected in 16 files: email-field.tsx, email-domains._index.tsx, schema.ts, signin.tsx and 12 more

Finding 6 of 23

[Section 8(1) — Security]

6. [HIGH] PLAINTEXT_PII_IN_LOGS — packages / lib / jobs / definitions / internal / sync-email-domains.handler.ts:30

Evidence snippet: io.logger.info('No pending email domains to sync');

Estimated fix time: 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Finding 7 of 23

[Section 8(1) — Security]

7. [HIGH] PLAINTEXT_PII_IN_LOGS — packages / lib / server-only / user / service-accounts / legacy-service-account.ts:23

Evidence snippet: console.log('Migrating legacy service account to new email: \${legacyServiceAccountEmail()}');

Estimated fix time: 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Finding 8 of 23

[Section 8(6) — Breach]

8. [MEDIUM] NO_ERROR_HANDLING_IN_AUTH — apps / remix / app / routes / _authenticated+ / admin+ / documents._index.tsx

Estimated fix time: 1–3 hours

Auth routes have no try/catch or try/except blocks. Errors may go unlogged.

Finding 9 of 23

[Section 8 — Data Principal Rights]

9. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A

Estimated fix time: 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: packages/auth/server/routes/email-password.ts, packages/ee/server-only/lib/send-organisation-account-link-confirmation-email.ts, packages/lib/server-only/2fa/email/send-2fa-token-email.ts, packages/lib/server-only/auth/create-passkey-registration-options.ts, packages/lib/server-only/document/complete-document-with-token.ts. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Fix:

1. Audit deletion endpoint to ensure it cascades to: packages/auth/server/routes/email-password.ts, packages/ee/server-only/lib/send-organisation-account-link-confirmation-email.ts, packages/lib/server-only/2fa/email/send-2fa-token-email.ts, packages/lib/server-only/auth/create-passkey-registration-options.ts, packages/lib/server-only/document/complete-document-with-token.ts.
2. Use database CASCADE DELETE or explicit multi-table deletion.
3. Add a deletion checklist in code comments listing every table that stores user PII.

Finding 10 of 23

[Section 8(4) — Audit Trail]

10. [MEDIUM] AUDIT_TRAIL_PARTIAL — apps / remix / app / routes / _internal+ / [__htmltopdf]+ / audit-log.tsx

Estimated fix time: 2–8 hours

Partial audit trail detected. Found: access logging, change tracking. Missing: dedicated audit model/table. DPDP Section 8(4) requires a structured audit trail with user identity, timestamp, action, and data accessed. A dedicated audit log table is required for proper compliance.

Finding 11 of 23

[Section 11 — Data Portability]

11. [LOW] DATA_PORTABILITY_MISSING — N / A

Estimated fix time: 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Finding 12 of 23

[Section 6 — Consent]

12. [PASS] CONSENT_PRESENT — apps / remix / app / routes / _internal+ / [__htmltopdf]+ / audit-log.tsx

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 13 of 23

[Section 6 — Consent]

13. [PASS] CONSENT_PRESENT — apps / remix / app / components / tables / inbox-table.tsx

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 14 of 23

[Section 6 — Consent]

14. [PASS] CONSENT_PRESENT — apps / remix / app / routes / _unauthenticated+ / o.\$orgUrl.signin.tsx

Framework auth/consent middleware detected in this file.

Finding 15 of 23

[Section 6 — Consent]

15. [PASS] CONSENT_PRESENT — packages / auth / server / index.ts

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 16 of 23

[Section 6 — Consent]

16. [PASS] CONSENT_PRESENT — packages / trpc / server / trpc.ts

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 17 of 23

[Section 6 — Consent]

17. [PASS] CONSENT_PRESENT — packages / auth / server / lib / utls / delete-account-provider.ts

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 18 of 23

[Section 6 — Consent]

18. [PASS] CONSENT_PRESENT — packages / trpc / server / context.ts

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 19 of 23

[Section 6 — Consent]

19. [PASS] CONSENT_PRESENT — apps / remix / app / components / general / document / document-edit-form.tsx

Consent covered via imported module: packages/lib/client-only/providers/session.tsx, packages/auth/server/lib/utls/get-session.ts

Finding 20 of 23

[Section 6(6) — Consent Withdrawal]

20. [PASS] CONSENT_WITHDRAWAL_PRESENT — apps / remix / app / components / dialogs / account-delete-dialog.tsx

Consent withdrawal mechanism detected. Found in:
apps/remix/app/components/dialogs/account-delete-dialog.tsx (line 25)

Finding 21 of 23

[Section 8 — Data Principal Rights]

21. [PASS] DELETION_MECHANISM_PRESENT — N / A

Data deletion mechanism detected. Found 0 deletion endpoint(s) and 137 deletion signal(s).
Cascade delete patterns detected.

Finding 22 of 23

[Section 8(6) — Breach]

22. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 23 of 23

[Section 11 — Right to Access]

23. [PASS] DATA_ACCESS_PRESENT — packages / api / hono.ts

Data access endpoint detected for authenticated users.